🧩 탐지 규칙(플러그인 방식) 올리기 안내

WARDEN 대시보드 > 탐지 규칙 메뉴 > "플러그인 방식 규칙 올리기" 에서 쓰는 방법입니다. 일반 도구는 "도구 올리기 안내" PDF를 보세요.

1. 플러그인 방식 규칙이란?

WARDEN 의 탐지 규칙은 두 가지입니다.

방식	누가 판정하나
🔥 방화벽 방식	WARDEN 이 지나가는 **패킷**을 직접 보고 판정 (포트 스캔, SYN 플러드 등). 대시보드의 "새 규칙 추가" 양식으로 만들 수 있습니다.
🧩 플러그인 방식	패킷 대신 **내가 만든 스크립트**가 판정합니다. WARDEN 이 정해진 주기마다 스크립트를 실행하고, 스크립트가 "이 IP 가 수상하다" 라고 출력하면 WARDEN 이 알림·차단을 합니다. (예: 로그인 기록 분석, 동시 접속 수 확인)

WARDEN 이 **interval_sec** 마다 스크립트 실행 ▶ 스크립트가 **판정만** 출력 (JSON 한 줄씩) ▶ WARDEN 이 화이트리스트 확인 · 알림 · (선택) 차단

> **역할 분담이 중요합니다.** 스크립트는 **판정만** 합니다. 차단(iptables)·화이트리스트 확인·로그 기록은 전부 WARDEN 이 합니다. 스크립트가 직접 방화벽을 건드리지 않습니다.

2. 올리는 방법 한눈에

① 파일 만들기
`rule.json` 과 판정 스크립트 (`.py` / `.sh`)를 만듭니다.

② 올리기
"플러그인 방식 규칙 올리기"에서 파일을 모두 선택해 올립니다.

③ (선택) 시험
"🧪 샌드박스로 실행"으로 설치 없이 한 번 돌려 봅니다.

④ 승인
관리자가 서버 터미널에서 코드를 읽고 승인하면 **꺼진 상태**로 설치됩니다.

⑤ 켜기
탐지 규칙 화면의 카드에서 직접 "켜기".

> **왜 이렇게 번거롭나요?** 규칙 스크립트는 WARDEN 이 계속 자동으로 실행하는 코드라서, 올리는 순간 실행되면 위험합니다. 그래서 (1) 올려도 실행되지 않고, (2) 승인은 서버 터미널에서만 가능하고, (3) 승인 뒤에도 꺼진 상태로 시작합니다. 대시보드에는 승인 버튼이 없습니다.

3. 올릴 파일

파일	설명
`rule.json` (필수)	규칙 설정 파일. 이름은 반드시 `rule.json`. (도구의 `plugin.json` 과 함께 올릴 수 없습니다.)
판정 스크립트 (필수)	`.py` 또는 `.sh`. `command` 의 첫 항목이 이 파일입니다. 필요하면 스크립트를 더 올릴 수 있습니다.

- 한 번에 **6개**까지, 파일당 **64KB** 까지. `rule.json` 외의 `.json` 파일은 올릴 수 없습니다.
- 스크립트는 승인되면 `rules/` 폴더에 그대로 놓입니다. 다른 규칙·파일과 이름이 겹치면 거부되므로 **규칙 id 를 접두어로** 쓰면 편합니다 (예: `many_connections.py`).
- 같은 `id` 를 다시 올리면 승인 대기 중인 이전 것을 덮어씁니다. 이미 `rules/` 에 있는 `id` 나 파일 이름은 올릴 수 없습니다.

4. rule.json 항목

```
{
  "id": "many_connections",
  "detector": "script",
  "name": "동시 접속 과다",
  "description": "한 IP 가 서버에 동시에 20개 이상 연결하면 알림",
  "tags": ["접속", "과다"],
  "command": ["./many_connections.py", "20"],
  "interval_sec": 10,
  "timeout_sec": 10,
  "severity": "warning",
  "block": false
}
```

항목	필수	설명
`id`	필수	영소문자로 시작, 영소문자·숫자·밑줄만, 40자까지. 기본 탐지기 이름 (`port_scan` `syn_flood` `icmp_flood` `ssh_bruteforce` `ssh_login_success` `arp_spoof` `exfiltration`)과 예약어 (`unblock` `manual_block` `syn_flood_distributed` `rule_toggle`)는 쓸 수 없습니다.
`detector`	필수	반드시 `"script"`.
`command`	필수	실행할 명령 목록 (1~6개). **첫 항목은 `./파일이름.py` (또는 `.sh`)**, 뒤는 스크립트에 넘길 인자입니다. `..` 금지. `./` 로 쓴 파일은 같이 올려야 합니다. **승인 뒤에는 화면에서 바꿀 수 없습니다** (바꾸려면 새로 올려서 승인).
`interval_sec`	필수	실행 주기 (5~3600초). WARDEN 이 이 간격마다 스크립트를 실행합니다.
`timeout_sec`	선택	한 번 실행의 시간 제한 (1~60초, 기본 10). 넘기면 강제 종료됩니다. 스크립트는 주기 안에 끝나게 만드세요.
`name` · `description`	권장	카드에 보일 이름(60자까지)·설명(200자까지).
`tags`	선택	카드 이름 밑에 **#포트공격** 처럼 보일 태그. 6개까지, 공백 없이 20자까지.
`severity`	선택	`info` (Low) / `warning` (Medium, 기본) / `critical` (Critical).
`block`	선택	`true` 면 스크립트가 알린 IP 를 방화벽으로 차단합니다 (기본 `false` = 알림만). 아래 "차단 주의" 참고.
`block_duration_sec` · `block_permanent`	선택	차단 기간(초) / 영구 차단. 안 쓰면 WARDEN 의 기본 차단 시간을 씁니다.
`notify`	선택	대시보드 알림. `{"popup": true, "sound": false}` 처럼 팝업·소리를 따로 정합니다. 생략하면 위험도 기본값 (Critical = 팝업+소리, Medium = 팝업, Low = 알림 없음). 승인 뒤 ⚙ 에서도 바꿀 수 있습니다.
`enabled`	무시됨	써도 무시되고 **항상 꺼진 상태**로 설치됩니다.

위 표에 없는 항목을 쓰면 오타를 막기 위해 거부됩니다.

5. 스크립트가 지켜야 할 출력 약속

스크립트는 수상한 대상이 있을 때만, **한 줄에 JSON 객체 하나씩** 표준출력(`print` / `echo`)으로 내보냅니다.

```
{"source": "192.168.56.20", "detail": "동시 접속 25개"}
```

키	설명
`source` (필수)	수상한 **IP 주소** (예: `192.168.56.20`) 또는 MAC (`mac:aa:bb:cc:dd:ee:ff`). 이 값이 IP/MAC 형식이 아니면 그 줄은 무시됩니다. `0.0.0.0/0` 같은 범위는 안 됩니다.
`detail` (선택)	화면에 보일 설명 (200자까지). 탐지 로그와 "ℹ 정보" 창에 나옵니다.

- **아무것도 출력하지 않으면 "이상 없음"**입니다.
- JSON 이 아닌 줄(디버그 출력 등)은 조용히 무시됩니다. 판정 외의 말은 `stderr` 로 쓰세요.
- 한 번 실행에 최대 **200줄**, 한 줄 **4096바이트** 까지만 읽고 나머지는 버립니다.
- 종료 코드가 0 이 아니고 출력도 없으면 "오류"로 보고 WARDEN 터미널에 한 번만 표시합니다 (같은 오류는 반복해서 찍지 않음).
- 같은 규칙·같은 IP 의 알림은 설정된 시간(기본 30초) 안에는 한 번만 기록됩니다.

6. 실행 환경

- 스크립트는 서버의 `rules/` 폴더에서 실행됩니다 (작업 폴더가 `rules/`).
- WARDEN 은 root 로 돌지만, 스크립트는 **일반 계정(`kali`) 권한으로 낮춰서** 실행됩니다. root 권한이 필요한 파일(일부 시스템 로그 등)은 읽지 못할 수 있으니, 승인 전에 서버에서 그 계정으로 읽히는지 확인하세요.
- 승인하면 스크립트는 실행 권한이 자동으로 붙어(`755`) 설치됩니다. 첫 줄에 `#!/usr/bin/env python3` 를 쓰는 것을 권장합니다.

7. 완성 예제 (그대로 올려서 시험해 볼 수 있습니다)

"한 IP 가 서버에 동시에 N개 이상 연결해 있으면 알린다". 위 `rule.json` 예제와 함께 쓰는 `many_connections.py` 입니다.

```
#!/usr/bin/env python3
# 한 IP 가 서버에 동시에 N개 이상 연결해 있으면 그 IP 를 알린다 (인자로 N, 기본 20)
import collections
import json
import subprocess
import sys

limit = int(sys.argv[1]) if len(sys.argv) > 1 else 20
out = subprocess.run(["ss", "-Htn", "state", "established"], capture_output=True,
text=True).stdout
count = collections.Counter()
for line in out.splitlines():
    cols = line.split()
    if len(cols) >= 4:                          # Recv-Q Send-Q 내주소:포트 상대주소:포트
        count[cols[3].rsplit(":", 1)[0].strip("[]")] += 1
for ip, n in count.items():
    if n >= limit:
        print(json.dumps({"source": ip, "detail": f"동시 접속 {n}개"}, ensure_ascii=False))
```

> 샌드박스 시험은 네트워크가 막힌 격리 상태라 `ss` 결과가 비어 있어 아무것도 출력되지 않을 수 있습니다 (오류가 아니라 "이상 없음"). 진짜 동작은 승인·설치한 뒤 켜서 확인하세요.

8. 올리기 · 시험 · 승인 · 켜기

(1) 올리기

대시보드 > 탐지 규칙 > "플러그인 방식 규칙 올리기" 에서 `rule.json` 과 스크립트를 **한꺼번에** 선택하고 "⬆ 올리기". 설정이 틀리면 이유가 바로 표시되고, 통과하면 "승인 대기 중" 목록에 나타납니다 (아직 적용되지 않습니다).

(2) 샌드박스로 시험 (선택)

승인 대기 항목의 **"🧪 샌드박스로 실행"**은 설치 없이 스크립트를 한 번만 돌려 출력이 약속대로(JSON 한 줄씩) 나오는지 볼 수 있습니다. 네트워크 없음 · 파일 읽기 전용 · 메모리·시간 제한. 결과는 저장되지 않습니다.

(3) 승인 (서버 터미널에서만)

```
cd ~/warden
python3 dashboard/approve_plugin.py list                # 승인 대기 목록 ([규칙] / [도구] 표시)
python3 dashboard/approve_plugin.py show many_connections    # 파일 내용과 주의할 패턴 보기
python3 dashboard/approve_plugin.py approve many_connections # 내용을 다시 보여 주고 해시를 입력하면 승인
python3 dashboard/approve_plugin.py reject many_connections  # 거절(삭제)
```

승인하면 스크립트와 `many_connections.json` 이 `rules/` 에 **꺼진 상태**로 설치되고, 5초 안에 탐지 규칙 화면의 "🧩 플러그인 방식" 에 카드가 나타납니다. 승인하는 사람은 **코드를 직접 읽어야** 합니다.

(4) 켜기

카드 오른쪽 위의 스위치로 켭니다. 켜기 전에 카드 아래의 위험도·차단 여부가 의도한 대로인지 확인하세요. 이름·위험도·주기·차단 여부는 ⚙ 로 수정할 수 있습니다 (수정하면 안전을 위해 꺼진 상태가 되고, 실행 명령은 바꿀 수 없습니다).

> **차단 주의 (`block: true`).** 스크립트가 틀린 IP 를 알리면 그 IP 가 실제로 차단됩니다. 화이트리스트에 있는 IP(관리 PC 등)는 차단되지 않지만, 그 외에는 정상 접속도 막힐 수 있습니다. 처음에는 `"block": false` (알림만)로 시험하고, 판정이 믿을 만한지 확인한 뒤에 차단을 켜세요. "탐지만(dry-run)" 모드(개요 메뉴의 슬라이드)에서는 차단이 실제로 적용되지 않으니 그 상태에서 먼저 시험하는 것도 좋습니다.

> **주의 표시는 보안 장치가 아닙니다.** `sudo`, `curl`, `subprocess` 같은 패턴이 있으면 "주의" 로 표시해 줄 뿐이고, 표시가 없다고 안전한 것은 아닙니다. 모르는 사람이 올린 코드는 승인하지 마세요.

9. 자주 나는 오류

메시지(요약)	고치는 법
rule.json (탐지 규칙) 이 필요한 칸 / plugin.json 과 함께 올릴 수 없음	파일 이름이 정확히 `rule.json` 인지, 규칙 칸에 올렸는지 확인. 도구 파일(`plugin.json`)은 섞지 마세요.
detector 는 "script" 여야 합니다	`"detector": "script"` 를 넣으세요.
'...' 는 기본 탐지기가 쓰는 이름입니다	`id` 를 다른 이름으로 바꾸세요.
rule.json 에 알 수 없는 항목이 있습니다	표에 없는 항목(오타 포함)을 지우세요.
command 의 첫 항목은 './파일이름.py'...	`"./스크립트.py"` 형식(`.py` / `.sh`)으로 쓰세요.
command 의 ./파일 이 함께 올라오지 않았습니다	스크립트 파일을 같이 선택해서 올리세요.
interval_sec 는 5~3600 사이의 정수	`interval_sec` 를 넣고 범위를 지키세요 (필수 항목).
rules/ 에 같은 이름의 파일이 이미 있습니다	`id` 나 스크립트 파일 이름을 바꾸세요 (규칙 id 를 접두어로).
같은 id 의 다른 종류가 승인 대기 중	먼저 삭제하거나 다른 `id` 를 쓰세요.
(켰는데 아무 일도 안 일어남)	스크립트가 정말 판정을 출력하는지(샌드박스·서버에서 직접 실행), 출력이 JSON 한 줄씩인지, `source` 가 올바른 IP 인지 확인하세요. 오류는 WARDEN 터미널에 한 번만 표시됩니다.

10. 올리기 전 점검표

- ☐ `rule.json` 에 `"detector": "script"` 와 `interval_sec` 가 있고, `id` 가 기본 탐지기 이름과 겹치지 않는다.
- ☐ `command` 첫 항목이 `./이름.py` (또는 `.sh`)이고 그 파일을 같이 올렸다.
- ☐ 스크립트가 수상한 대상만 `{"source": "IP", "detail": "…"}` 한 줄씩 출력하고, 이상 없으면 아무것도 출력하지 않는다.
- ☐ 일반 계정 권한으로 읽을 수 있는 정보만 쓰고, 주기(`interval_sec`) 안에 끝난다.
- ☐ 처음에는 `"block": false` 로 시험한다.
- ☐ `tags` 로 무슨 규칙인지 알 수 있게 달았다 (예: `#접속`).